Blueprint Belajar Cyber Security dengan Prinsip Pareto (80/20)

Nov 12, 2026 · @alam

1. Pendahuluan: Pareto untuk Cyber Security

Target blueprint ini: dalam 90 hari kamu bisa mengerjakan tugas dasar analis keamanan atau pentester junior, dengan belajar sekitar 20% topik yang menghasilkan 80% kemampuan praktis.

Prinsip Pareto (80/20) berarti sebagian kecil input menghasilkan sebagian besar hasil. Cyber security sangat luas, sehingga mencoba mempelajari semuanya adalah jebakan paling umum bagi pemula. Strateginya:

- **Pilih sedikit, dalami:** kuasai fondasi yang dipakai di hampir semua peran.
- **Praktik di atas teori:** sekitar 70% waktu untuk lab dan latihan, 30% untuk membaca dan menonton.
- **Spesialisasi belakangan:** pilih jalur setelah fondasi kuat (minggu 7 ke atas).
- **Buang yang belum perlu:** exploit development tingkat lanjut, reverse engineering, dan forensik mendalam bisa menunggu.

Asumsi: kamu bisa meluangkan 10 jam per minggu (sekitar 1,5 jam per hari). Jika waktumu lebih sedikit, perpanjang jadwal secara proporsional.

2. Peta 20% Inti yang Memberi 80% Hasil

Tujuh topik berikut dipakai di hampir semua peran keamanan. Kuasai ini sebelum yang lain.

#	Topik inti	Mengapa berdampak besar	Yang cukup dipelajari
1	Jaringan (TCP/IP)	Hampir semua serangan dan pertahanan lewat jaringan	OSI singkat, IP, subnet, DNS, HTTP/HTTPS, port umum, membaca paket di Wireshark
2	Linux & command line	Sebagian besar tools keamanan berjalan di Linux	Navigasi, izin file, proses, grep/awk, SSH, manajemen paket
3	Keamanan web	Aplikasi web adalah sasaran paling sering	OWASP Top 10: injection, XSS, auth rusak, akses kontrol rusak

#	Topik inti	Mengapa berdampak besar	Yang cukup dipelajari
4	Scripting (Python & Bash)	Mengotomatiskan tugas berulang	Baca/tulis file, request HTTP, parsing log, loop dan fungsi
5	Kriptografi dasar	Dasar konsep kerahasiaan dan integritas	Hash vs enkripsi, simetris vs asimetris, TLS, sertifikat, manajemen password
6	Identitas & akses	Kredensial yang dicuri adalah penyebab pelanggaran terbanyak	Autentikasi, MFA, prinsip least privilege, dasar Active Directory
7	Pola serangan & deteksi	Menghubungkan semuanya menjadi cara berpikir	Kerangka MITRE ATT&CK, cyber kill chain, phishing, malware umum, membaca log

Aturan 80/20 untuk tiap topik: belajar secukupnya untuk menyelesaikan satu lab praktik, lalu lanjut. Kembali memperdalam hanya saat lab berikutnya memintanya.

3. Roadmap 90 Hari (13 Minggu)

Tiga fase: fondasi (minggu 1-6), spesialisasi awal (minggu 7-10), portofolio (minggu 11-13). Setiap minggu punya satu output yang bisa dibuktikan.

Minggu	Fokus	Aktivitas utama	Output
1-2	Linux & command line	OverTheWire Bandit level 0-15, instal Kali/Ubuntu di VM	Catatan perintah dan 15 level Bandit selesai
3-4	Jaringan	Cisco Networking Basics atau Professor Messer N10; capture paket dengan Wireshark	Laporan analisis satu capture (DNS, HTTP, TCP handshake)
5-6	Python & Bash	Tulis port scanner sederhana dan parser log	Dua skrip di GitHub
7-8	Keamanan web	PortSwigger Web Security Academy: SQLi, XSS, autentikasi; OWASP Juice Shop	10 lab PortSwigger selesai, write-up singkat
9	Kriptografi & identitas	Hash, TLS, MFA, dasar Active Directory	Ringkasan satu halaman dan satu lab hash cracking

Minggu	Fokus	Aktivitas utama	Output
10	Deteksi & respons	TryHackMe SOC Level 1 (sebagian), MITRE ATT&CK, analisis log	Investigasi satu insiden simulasi
11-12	Proyek portofolio	Satu proyek: home lab, atau 3 mesin CTF lengkap dengan write-up	Repositori GitHub dengan dokumentasi
13	Konsolidasi	Ulang topik terlemah, mock interview, pilih jalur lanjutan	Rencana 6 bulan ke depan

Gerbang kelulusan fase: jangan pindah fase sebelum output minggu terakhir fase itu selesai. Output yang terbukti lebih penting daripada jumlah jam.

4. Memilih Jalur Spesialisasi

Setelah fondasi, pilih satu jalur untuk 3-6 bulan berikutnya. Mendalami satu jalur lebih bernilai daripada menyentuh semuanya.

Jalur	Pekerjaan sehari-hari	Cocok jika kamu	Fokus belajar berikutnya
Blue Team / SOC	Memantau alert, menganalisis log, merespons insiden	Teliti, suka menyelidiki pola	SIEM (Splunk/Elastic), analisis log, incident response
Red Team / Pentest	Mencari celah secara sah pada sistem klien	Suka memecahkan teka-teki, sabar mencoba	Metodologi pentest, Burp Suite, Active Directory attack, pelaporan
Cloud Security	Mengamankan konfigurasi AWS/Azure/GCP	Tertarik infrastruktur dan otomatisasi	IAM cloud, konfigurasi aman, Infrastructure as Code
GRC (tata kelola & kepatuhan)	Risiko, kebijakan, audit	Kuat dalam komunikasi dan dokumentasi, kurang ingin teknis mendalam	ISO 27001, NIST CSF, penilaian risiko

Cara memilih cepat (satu minggu): kerjakan satu lab dari tiap jalur (misal 1 hari per jalur). Jalur yang membuatmu lupa waktu adalah kandidat utama. Jika ragu, mulai dari Blue Team/SOC karena lowongan junior paling banyak dan fondasinya bisa dialihkan ke jalur lain.

5. Lab dan Tools yang Paling Sering Dipakai

Lab gratis di komputer sendiri sudah cukup untuk 90 hari pertama. Spesifikasi minimal yang nyaman: RAM 8 GB (16 GB lebih baik), ruang disk 60 GB.

Setup lab (satu akhir pekan):

1. Instal VirtualBox atau VMware Workstation Player.
2. Buat VM Kali Linux (mesin penyerang) dan satu VM target, misalnya Metasploitable 2 atau DVWA.
3. Atur jaringan *host-only* agar target terisolasi dari internet.
4. Ambil snapshot VM bersih sebelum mulai bereksperimen.

Tools 20% yang menutup 80% kebutuhan awal:

Kategori	Tool	Dipakai untuk
Analisis jaringan	Wireshark, tcpdump	Membaca dan menyaring paket
Pemindaian	Nmap	Menemukan host, port, dan layanan
Web	Burp Suite Community	Mencegat dan memodifikasi request HTTP
Password	Hashcat, John the Ripper	Menguji kekuatan hash (di lab sendiri)
Eksploitasi	Metasploit Framework	Memahami alur eksploitasi terkontrol
Deteksi & log	Splunk Free, Elastic Stack, Sysmon	Mencari jejak aktivitas mencurigakan
Catatan	Obsidian atau Notion	Mendokumentasikan setiap lab sebagai write-up

Pelajari tiap tool lewat kasus nyata di lab, bukan dengan membaca seluruh dokumentasinya.

6. Platform, Sertifikasi, dan Sumber Belajar

Pilih satu platform utama, bukan semuanya. Harga dan katalog dapat berubah, jadi periksa situs resminya sebelum berlangganan (informasi ini berdasarkan pengetahuan umum, bukan hasil pengecekan terbaru).

Kebutuhan	Pilihan berdampak tinggi	Catatan
Belajar terpandu dari nol	TryHackMe (jalur Pre Security, lalu Jr Penetration Tester atau SOC Level 1)	Ramah pemula, banyak materi gratis
Latihan keamanan web	PortSwigger Web Security Academy	Gratis dan sangat berkualitas
Latihan command line	OverTheWire (Bandit)	Gratis
Tantangan lebih sulit	Hack The Box, picoCTF	Mulai setelah minggu 8
Video fondasi IT	Professor Messer, kursus Networking Basics Cisco	Gratis
Standar referensi	OWASP Top 10, MITRE ATT&CK	Gratis dan dipakai industri

Sertifikasi (Pareto: ambil satu dulu, bukan semuanya):

- **CompTIA Security+:** paling umum diminta untuk peran junior dan sering menjadi syarat HR. Cocok sebagai target pertama jika tujuanmu pekerjaan.
- **eJPT atau PNPT:** lebih praktis jika memilih jalur pentest.
- **BTL1 atau SC-200:** cocok untuk jalur Blue Team.
- **Sertifikasi lanjutan (CISSP, OSCP):** tunda sampai punya pengalaman. Jangan mengejarnya di tahun pertama.

Sertifikasi membuka pintu wawancara, sedangkan portofolio write-up dan kemampuan praktik yang membuatmu lolos wawancara.

7. Sistem Belajar dan 80% yang Diabaikan

Jadwal mingguan (10 jam):

Blok	Durasi	Isi
Teori terarah	3 jam	Video atau bacaan untuk satu topik minggu ini

Blok	Durasi	Isi
Lab praktik	5 jam	Latihan langsung di TryHackMe, PortSwigger, atau VM sendiri
Write-up & catatan	1,5 jam	Tulis apa yang dikerjakan dan mengapa berhasil
Review mingguan	0,5 jam	Cek output minggu ini, tentukan fokus minggu depan

Metrik progres (cek tiap akhir minggu):

- Apakah output minggu ini selesai dan terdokumentasi?
- Berapa lab yang selesai tanpa melihat solusi?
- Bisakah kamu menjelaskan topik minggu ini dalam 2 menit tanpa catatan?

Yang sengaja diabaikan dulu (80% rendah dampak untuk pemula):

- Mengoleksi puluhan tools yang belum dipakai di lab.
- Menonton kursus berjam-jam tanpa praktik (*tutorial hell*).
- Reverse engineering, exploit development, dan forensik memori mendalam.
- Berpindah-pindah jalur setiap minggu.
- Mengejar banyak sertifikasi sekaligus.

Kebiasaan yang mempercepat belajar: menulis write-up untuk setiap lab, mengajarkan kembali ke orang lain atau di blog, dan bergabung di komunitas (Discord TryHackMe, komunitas keamanan lokal) untuk bertanya saat macet lebih dari 30 menit.

8. Etika, Hukum, dan Langkah Setelah 90 Hari

Aturan wajib: hanya uji sistem milikmu sendiri, lab yang disediakan untuk latihan, atau target dengan izin tertulis. Mengakses sistem tanpa izin melanggar hukum, termasuk UU ITE di Indonesia, meskipun niatnya belajar. Program bug bounty resmi (misalnya HackerOne atau Bugcrowd) memberi izin yang jelas dalam ruang lingkup tertentu.

Setelah minggu 13:

1. Masuk jalur terpilih selama 3 bulan berikutnya dengan satu proyek besar (home SOC, laporan pentest lengkap, atau lab keamanan cloud).
2. Ambil sertifikasi pertama (misalnya Security+) bila tujuanmu pekerjaan.
3. Bangun jejak publik: GitHub rapi, blog write-up, profil LinkedIn.
4. Ikut CTF dan komunitas lokal untuk jaringan dan umpan balik.
5. Lamar posisi junior (SOC analyst, junior pentester, security intern) setelah punya 3-5 write-up dan satu proyek.

Checklist kesiapan akhir:

- [x] ~~Bisa menjelaskan cara kerja DNS, HTTP, dan TLS dengan kata sendiri~~
- [ ] Nyaman memakai terminal Linux untuk tugas harian
- [ ] Menyelesaikan minimal 10 lab keamanan web
- [ ] Punya 2 skrip Python/Bash di GitHub
- [x] ~~Punya 3 write-up dan satu proyek portofolio~~
- [ ] Sudah memilih jalur spesialisasi dan tahu langkah 6 bulan ke depan